Análise de arquivo suspeito

Share

codigo.py

PY

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Lendo o arquivo codigo.py anexado

Vou começar lendo o arquivo, sem executá-lo, apenas com análise estática.

Ran 5 commands, read a file
Terminei de ler as quase 590 linhas e agora confirmo o final do arquivo e busco indicadores de comprometimento antes de dar o veredito.

Ran a command

Fiz uma análise estática: li o código inteiro e não executei nada.

Análise passo a passo

1. Identificação. É um script Python de 588 linhas, em texto puro e sem ofuscação (SHA-256: `0524a469…867e1cd7`). Os comentários e mensagens estão em chinês, o que não basta para atribuir autoria. O arquivo funciona como *dropper*: carrega dentro de si outros scripts e os grava no disco.

2. Instalação (exige root). Instala `masscan`, `screen`, `python3-venv` e outros pacotes. Cria diretórios ocultos (`/root/.s/`, `/root/.a/`) e `/opt/monitor/`, e baixa de `del.sou.pp.ua` uma lista de faixas de IP a varrer e uma lista de IPs a excluir.

3. Varredura em massa. O `run_scan.sh` roda em laço infinito. Ele usa o masscan nas portas 22 e 5522 (SSH) a até 20.000 pacotes/s, sobre faixas de IP vindas de um servidor remoto, ou seja, máquinas que o operador não controla.

4. Ataque de credenciais. O `ssh_scanner.py` tenta login como `root` em cada IP encontrado, com 100 threads e duas senhas fixas e fracas. Os acertos são gravados em `/root/.a/`.

5. Propagação (comportamento de worm). O `monitor_script.py` lê esses acertos, entra na máquina invadida por SSH e envia uma cópia do próprio código para `/tmp`. Instala o Python se faltar, executa a cópia e apaga o arquivo. A vítima passa a varrer e atacar outras máquinas.

6. Agente de controle. Na vítima, instala o `komari-agent`, uma ferramenta de monitoramento legítima, configurada para se registrar em `sexy.pp.ua`, um servidor do

atacante. Com isso o atacante ganha um canal de gestão sobre a máquina comprometida. Também registra a vítima em uma API central (`sou.pp.ua`) para não reinfectar.

7. Exfiltração. Para cada máquina invadida, envia a um chat do Telegram o IP:porta, o usuário e a senha que funcionou, e o resultado de cada etapa. O token do bot está embutido no código (não o reproduzo aqui).

8. Persistência e ocultação. Cria os serviços systemd `scan-runner.service` e `file-monitor.service` , com `Restart=always` , rodando como root. Depois apaga o próprio arquivo 2 segundos após a instalação (`rm`), limpa arquivos intermediários e usa pastas ocultas.

Conclusão

O arquivo é malware, com confiança muito alta. Trata-se de um worm de SSH que varre a internet, quebra senhas de root, se replica, instala um agente de controle e entrega as credenciais ao atacante via Telegram. Nenhum uso legítimo explica a combinação de autorreplicação, autoexclusão, persistência escondida e envio de senhas roubadas.

Indicadores de comprometimento

- **Arquivos:** `/root/.s/` , `/root/.a/` (`LeitboGi0ro.txt` , `q123.txt`), `/opt/monitor/` (`bendi.py` , `monitor_script.py`), `/tmp/bendi.py` , `/var/log/vps-monitor.log`
- **Serviços:** `scan-runner.service` , `file-monitor.service`
- **Domínios:** `sou.pp.ua` , `del.sou.pp.ua` , `sexy.pp.ua` , além de `api.telegram.org` com bot fixo
- **Senhas testadas:** `LeitboGi0ro` e `123@@@` (se algum servidor seu aceita uma delas para root, trate-o como comprometido)
- **Comportamento:** sessões `screen` chamadas `masscan_scan_*` e `ssh_scan_*` , e muito tráfego SSH de saída

O que fazer

- **Não execute o arquivo.**
- **Se achou isso em um servidor seu:** isole a máquina, preserve evidências e pare e remova os dois serviços. Procure também o `komari-agent` instalado, troque todas as credenciais e desative login SSH por senha, principalmente para root. O mais seguro é reconstruir a máquina a partir de uma imagem limpa.
- **Denúncia:** vale reportar os domínios ao registrador ou hospedeiro e o bot ao abuso do Telegram.

Se quiser, posso ajudar a montar um checklist de resposta a incidente para o seu caso.

Qual é a categoria principal deste malware?

Avaliando os tipos de propagação e comportamento do malware ▸

A categoria principal é **worm (verme de rede)**, mais especificamente um worm de SSH que se propaga por força bruta de senhas.

O que define um worm é a autorreplicação automática, sem ação do usuário, e é exatamente o que ocorre aqui. O código encontra máquinas com SSH aberto, entra nelas com senhas fracas e copia o próprio código para lá. Em seguida o executa na vítima, que recomeça o ciclo e passa a atacar outras máquinas.

Ele também reúne comportamentos de outras categorias, mas todos servem à propagação ou ao controle das vítimas:

- **Dropper/instalador:** na primeira etapa, grava os componentes no disco e cria a persistência via systemd.
- **Scanner e brute-forcer:** varre faixas de IP com masscan e testa senhas fixas para root.
- **Credential stealer:** envia o IP, o usuário e a senha de cada máquina invadida para um bot do Telegram.
- **Enrollment de botnet:** instala um agente de monitoramento que registra a vítima em um servidor do atacante.

Portanto, no vocabulário de classificação de antivírus, ele seria rotulado como algo como *Worm.Linux.SSH* ou *SSH-Bruteforce Worm*, com traços de *botnet loader*.